

Bachelor's Thesis Proposal

Modeling and Enforcing Data Subject Rights for Unauthenticated Users

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

Model-driven privacy [2] (MDP) is a software development methodology in which privacy requirements are specified as models, and enforcement mechanisms are generated automatically via model transformations. MDP enables developers to specify three interconnected declarative models: a data model describing the state space of the system, a security model capturing fine-grained access control requirements, and a privacy model expressing data protection requirements, which is a particularly challenging class of privacy requirements. From these models, our methodology automatically generates a web application together with enforcement mechanisms that make it security- and privacy-aware by design.

2 Objective

A central concept in MDP is the *owner* of a piece of personal data: the data subject to whom the data pertains and whose consent and data subject rights govern how it may be used. The current MDP approach assumes that ownership is restricted to *authenticated* users, i.e., users who have already registered and authenticated with the system.

Personal data, however, is frequently collected about *unauthenticated* subjects, i.e., visitors who are tracked before they log in, individuals whose data is entered by someone else, or people who never register at all. Under data protection law, such information is still personal data relating to a data subject, so excluding unauthenticated users from ownership leaves a gap between the model and the system's actual legal obligations.

In this thesis, we aim to relax this assumption, enabling unauthenticated users to be treated as the owners of their personal data.

3 Tasks

1. Study the existing MDP approach.
2. Design a conceptual extension that allows unauthenticated users to act as data owners, including how such owners are represented and identified.
3. Propose how ownership is managed when a subject later registers or authenticates.
4. Realize the extension in the MDP modeling language and its enforcement.
5. Validate the extended approach in a case-study application.
6. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20-minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [2] Srdan Krstic, Hoang Nguyen Phuoc Bao, and David A. Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.